VULNSCAN 0.1.0 · FIELD CARD

Engagement commands

PYTHON3 -M VULNSCAN FROM THE REPO ROOT
AUTHORISED TARGETS ONLY

THE SCAN

```
python3 -m vulnscan 10.0.0.5              # everything, automatic
python3 -m vulnscan 10.0.0.5 --no-pdf     # skip slow PDF render
python3 -m vulnscan 10.0.0.0/29 -q        # range, quiet
```

Defaults: 60 common ports · engine `auto` · HTML+JSON to `out/` · PDF to Downloads · exit `1` if findings.

CLIENT DELIVERABLE

```
python3 -m vulnscan 10.0.0.5 \
  -p 22,80,443,3306,6379 --strict \
  --reference "SOW-2026-014" --csv \
  -r "ACME Q1 external"
```

`--strict` = proved findings only; the suppressed count is still printed in the coverage section. `--csv` = asset inventory (host, port, service, version, CPE).

PORTS

`-p top`	60 common ports (default)
`-p all`	1–65535, minutes per host
`-p 8000-8100`	inclusive range
`-p 22,80,8000-8100`	lists and ranges mix

TARGETS

```
python3 -m vulnscan a.example.com
python3 -m vulnscan 10.0.0.5,10.0.0.6
python3 -m vulnscan 10.0.0.0/29        # max 1024 hosts
```

Hostnames, IPv4, single IPv6, IPv4 CIDR. Refuses ranges over 1024 addresses.

ENGINES

```
--engine auto      # nmap if installed, else native
--engine native    # stdlib only, no nmap
--engine nmap      # require nmap, fail if absent
```

Native classifies the first bytes on the wire, one connection per port. nmap delegates to `-sV` plus scripts.

NMAP EVIDENCE

`--nse safe`	default · safe-tagged scripts only
`--nse extended`	+ ssl-enum-ciphers, ssh-auth-methods, http-enum
`--nse off`	identification only
`--version-intensity 7`	2–9, higher finds more

Vuln, exploit, DoS and brute script categories are never run, under any profile.

READING CONFIDENCE

`certain`	protocol-level proof on the wire; safe to quote to a client
`firm`	strong signal, not directly proved; verify before you report it
`tentative`	version or path hint only, or a distro build that may be backported

Every finding carries the evidence that produced it — the request sent and the response received — plus its CVSS vector when one is known.

WHEN A SCAN LOOKS WRONG

- **Fell back to native** — nmap not on `PATH`; coverage section says so.
- **No PDF** — needs Edge or Chrome; use `--no-pdf` and print the HTML.
- **Slow** — avoid `-p all`; try `-t 1.0` and fewer ports.
- **All timeouts** — filtered host; raise `-t`, lower `-c`.
- **Odd CVE** — read the backport note; `--update-db` for current ranges.

SPEED & NETWORK

`-t 1.0`	per-probe timeout (default 2.5s)
`-c 512`	concurrent probes (default 256)
`--legacy-tls`	also test TLS 1.0/1.1
`-q --no-color`	clean logs for CI

ARTIFACTS

```
-o ./reports            # HTML + JSON
--pdf-dir ./reports     # PDF location
-r "ACME Q1 external"   # name report + files
--html r.html --json r.json --pdf r.pdf
--csv assets.csv        # inventory rows
--no-html --no-json     # PDF only
```

CVE DATABASE (OFFLINE)

```
python3 -m vulnscan --update-db                 # last 6 years, NVD
python3 -m vulnscan --update-db --db-years 2021,2024
python3 -m vulnscan host --db ./advisories.sqlite3
VULNSCAN_DB=/path/db.sqlite3 python3 -m vulnscan host
```

Only `--update-db` uses the network. Cache at `~/.cache/vulnscan`. Range matching; distro builds downgraded to *tentative* for backports.

SAVED DEFAULTS

```
--set-output-dir ./reports --set-pdf-dir ./reports
--show-config     --reset-config
```

LAB / PROOF CHECKS

```
python3 -m vulnscan 127.0.0.1 -p 21,22,23,25,6379
python3 -m vulnscan --lab-exploits   # no target argument
```

Loopback-only, non-destructive, fixed proofs. Passing a target exits `2`.

RECIPES

```
# CI gate
python3 -m vulnscan 10.0.0.5 -q --no-pdf \
  || echo "findings present"

# no nmap, fast LAN
python3 -m vulnscan 10.0.0.5 \
  -p 1-1024 --engine native -t 1.5

# deep single-host pass
python3 -m vulnscan app.example.com \
  -p all --engine nmap --nse extended \
  --version-intensity 7 -c 128 \
  --reference "SOW-2026-014"
```

TRIAGE ORDER

- Unauthenticated data stores — `6379` Redis, `27017` Mongo, `9200` Elasticsearch.
- Control planes — `2375/2376` Docker, `10250` kubelet, `2379` etcd.
- Remote access — `3389` RDP, `5900` VNC, `22` SSH auth methods.
- Exposure hygiene — legacy TLS, expired certificates, version EOL.

BEFORE IT GOES TO THE CLIENT

- `--strict` run is the deliverable; the loose run stays in your notes.
- `--reference` matches the SOW; scope section names the same targets.
- Coverage section read: what was scanned, what was suppressed, was the CVE DB present.
- Inventory CSV attached for their asset register.

WHAT LANDS IN THE REPORT

- Scope, engine provenance, exact command line, any fallback reason.
- Per-service identity: product, version, CPE, and whether it came from a banner, a handshake or a port guess.
- Findings with severity, confidence, evidence, CVSS vector, plus per-host rollup.
- Coverage: ports scanned, suppressed counts, advisory DB present.
- Raw nmap XML beside the report (`*.nmap.xml`) when nmap ran.

EXIT CODES
0 clean · **1** findings · **2** bad spec

ON DISK
`out/` HTML+JSON · PDF Downloads

CONFIDENCE
`--strict` = proved only

NEVER
no auth · no exploit payloads